

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 30

Domain II - Information Security Risk Management

30 Questions	48 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 48 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM8-028)

Which statement BEST describes a threat?

- A. A weakness that may be exploited
- B. A business consequence after an event
- C. A potential cause of an unwanted event that may exploit a vulnerability
- D. The risk remaining after controls

Question 2 (CISM8-029)

Why should an assessment estimate both inherent and residual risk?

- A. To show exposure before controls and what remains with current controls
- B. To replace business judgment with a score
- C. To guarantee a financial return on every control
- D. To prove that controls eliminate risk

Question 3 (CISM8-030)

Scenario: A nonprofit will begin collecting donor data in a country not covered by its existing assessment. Data-processing partners, contractual commitments, and local obligations differ from its home market.

What should the information security manager do FIRST?

- A. Establish the new context before assessing scenarios
- B. Reuse the home-market rating
- C. Rate every scenario high
- D. Wait for the first donation

Question 4 (CISM8-031)

Scenario: A clinic rates a messaging broker as low because it stores messages only briefly. The broker routes medication orders between prescribers, pharmacies, and allergy-checking services.

Which action is MOST appropriate?

- A. Use the broker vendor's generic classification
- B. Retain the rating because storage is temporary
- C. Assess only message confidentiality
- D. Reassess availability and integrity impact across the medication-ordering process

Question 5 (CISM8-032)

Scenario: A remote-work company contracts with two network providers for resilience. Both lease their last-mile connectivity from the same carrier in the company's largest region.

Which risk should be documented?

- A. Different provider invoices
- B. A shared last-mile failure could disable both providers simultaneously
- C. Higher risk solely because services are outsourced
- D. Guaranteed compromise of remote devices

Question 6 (CISM8-033)

Scenario: An aerospace firm must protect design archives for 25 years. Its assessment considers current attacks but not future cryptographic weakness, data-harvesting risk, or migration complexity.

What is the PRIMARY assessment gap?

- A. Archive storage cost is missing
- B. Data lifetime, future decryption exposure, crypto-agility, and migration dependencies were omitted
- C. Current controls guarantee protection for the full period
- D. All encryption must be replaced immediately

Question 7 (CISM8-034)

When is a structured qualitative method MOST appropriate?

- A. When business impact is not relevant
- B. When an exact loss forecast is required
- C. When technical scores can be converted directly to currency
- D. When defined expert judgment must support prioritization despite limited numerical data

Question 8 (CISM8-035)

Scenario: A digital publishing platform is valued at \$1,500,000. A modeled event would affect 12% of that value. Management wants the single loss expectancy before considering frequency.

What is the single loss expectancy?

- A. \$18,000
- B. \$1,320,000
- C. \$125,000
- D. \$180,000

Question 9 (CISM8-036)

Scenario: A manufacturer reviews supplier access quarterly. Reviews are completed on time, but the procedure excludes emergency support accounts by design.

What is the PRIMARY issue?

- A. An incomplete review design
- B. An operating deficiency
- C. An impact
- D. Proof of misuse

Question 10 (CISM8-037)

Scenario: A property portal is rated low based on a planned control and a supplier's undated claim that attacks are rare. The register records neither source nor review date.

What should the information security manager do FIRST?

- A. Remove the scenario
- B. Keep the rating because two assumptions support it
- C. Reassess using current controls and document sources, dates, assumptions, owner, and target state
- D. Treat the supplier claim as independent validation

Question 11 (CISM8-038)

Scenario: A research institute uses a managed data warehouse. The provider secures infrastructure, while the institute must configure access and logging. The project assumes all controls are provider-operated.

What is the MOST important finding?

- A. Managed services remove customer accountability
- B. Unassigned customer responsibilities may leave access and logging controls ineffective
- C. Cloud use guarantees higher inherent risk
- D. Provider assurance covers institute configuration

Question 12 (CISM8-039)

Scenario: Two equal-rated acquisition risks compete for treatment. One affects a payroll archive with a tested workaround; the other could block customer migration required for closing next week.

Which should be prioritized?

- A. The archive because payroll data is always first
- B. Whichever has more vulnerabilities
- C. Neither because ratings match
- D. The migration risk because its transaction impact is imminent

Question 13 (CISM8-040)

Scenario: A simulation based on limited events produces a broad annual-loss range, but management asks for one exact number.

What should be presented?

- A. A range with assumptions, confidence, and sensitivity
- B. Only the maximum
- C. A vulnerability score converted to currency
- D. No estimate

Question 14 (CISM8-041)

Scenario: Five units rate reliance on a central secrets service as medium within local tolerance. One outage would stop all units and exceed enterprise appetite.

What is the BEST assessment action?

- A. Average the local ratings
- B. Delete local entries
- C. Report aggregate concentration while retaining local records
- D. Ignore enterprise appetite

Question 15 (CISM8-042)

Scenario: A utility board must fund resilience for customer outage communications. The report lists technical findings but no customer-impact scenario or treatment comparison.

What should be presented FIRST?

- A. Every scanner finding
- B. Assessment hours
- C. A request to buy all controls
- D. Material scenarios, appetite, assumptions, and treatments

Question 16 (CISM8-043)

Which action BEST represents risk avoidance?

- A. Discontinuing the activity that creates the exposure
- B. Purchasing insurance
- C. Implementing a preventive control
- D. Formally retaining exposure

Question 17 (CISM8-044)

Who should formally accept residual risk?

- A. The authorized business risk owner
- B. The control operator
- C. The assessor
- D. The external auditor

Question 18 (CISM8-045)

Scenario: An event organizer buys insurance for notification expenses. Service interruption, reputation, exclusions, and customer obligations remain.

How should the response be recorded?

- A. Complete avoidance
- B. Partial financial transfer with other exposure retained
- C. Transfer of accountability
- D. Elimination of impact

Question 19 (CISM8-046)

Scenario: A records service must encrypt regulated data. A cheaper access control lowers risk but does not meet the binding encryption duty. A compliant option reduces risk within tolerance.

What should be recommended?

- A. Insurance instead of encryption
- B. The cheaper control
- C. Acceptance by the administrator
- D. The compliant option meeting acceptable residual risk

Question 20 (CISM8-047)

Scenario: Two controls reduce loyalty-fraud risk within tolerance. Control X costs twice as much and delays customers; Control Y meets obligations without material delay.

Which should be recommended?

- A. Choose lower-impact Control Y
- B. Control X
- C. Both controls
- D. Neither because risk remains

Question 21 (CISM8-048)

Scenario: A student-services project has an above-tolerance privacy risk, but its treatment has no owner, funding, or launch criterion.

What is the BEST corrective action?

- A. Move it to a postlaunch backlog
- B. Ask developers to accept it
- C. Fund treatment and require acceptable residual-risk evidence at launch
- D. Lower the rating

Question 22 (CISM8-049)

What is the PRIMARY purpose of a key risk indicator?

- A. To count all security activities
- B. Early evidence that exposure is approaching a defined threshold
- C. To replace risk assessment
- D. To prove every loss has occurred

Question 23 (CISM8-050)

Scenario: A media company learns after signature that a localization vendor sends unreleased content to an unreviewed subcontractor. Security review begins during implementation.

Which process change is MOST effective?

- A. Review after launch
- B. Require risk-tiered data and subcontractor review
- C. Ban every subcontractor
- D. Let procurement accept all risk

Question 24 (CISM8-051)

Scenario: A laboratory cannot patch a certified analyzer. Network isolation is proposed, but testing identifies a remote-support path that bypasses the isolation rule.

What should the information security manager do FIRST?

- A. Approve because isolation exists
- B. Ignore the support path
- C. Reassess coverage and residual risk before exception approval
- D. Accept the risk for the laboratory

Question 25 (CISM8-052)

Scenario: A temporary acceptance requires failed backup jobs to remain below 3%. The rate reaches 9% for two periods, meeting the documented trigger.

What should happen NEXT?

- A. Raise the threshold
- B. Invoke reassessment and a revised owner decision
- C. Wait for data loss
- D. Close the risk

Question 26 (CISM8-053)

Scenario: A 60-day endpoint exception has been renewed five times. Its compensating control was never tested, and the original approver has left.

What is the BEST action?

- A. Reassess exposure and controls
- B. Close the exception
- C. Make it permanent
- D. Renew automatically

Question 27 (CISM8-054)

Scenario: A warehouse service was accepted for internal use with daily reconciliation. A change adds supplier access and replaces reconciliation with monthly sampling.

What should occur before approval?

- A. Keep the prior acceptance
- B. Ask suppliers to accept risk
- C. Reassess because exposure and a key control assumption changed
- D. Approve because the service is unchanged

Question 28 (CISM8-055)

Scenario: Five divisions independently delay replacing the same unsupported appliance. All protect services for one major customer and depend on one support team. Aggregate exposure exceeds appetite.

What should be reported?

- A. Only the oldest appliance
- B. Aggregate concentration, local decisions, trend, and required action
- C. Only technical severity
- D. Nothing until a local limit is exceeded

Question 29 (CISM8-056)

Scenario: An acquired dispatch system is unsupported but essential for four months. Isolation and monitoring reduce risk to an approved temporary tolerance while migration proceeds.

Which response is BEST?

- A. Shut down regardless of impact
- B. Accept indefinitely
- C. Use time-bound controls, documented acceptance, monitoring triggers, and a migration deadline
- D. Rely on the seller's history

Question 30 (CISM8-057)

Scenario: Executives receive overdue-task counts but cannot see whether third-party exposure is improving or what decision they must make.

Which reporting approach is MOST appropriate?

- A. Add every raw task
- B. Wait until treatment completes
- C. Report only spending
- D. Material risk, treatment, exceptions, and decisions

Answer Key

Domain II - Information Security Risk Management

1 C	2 A	3 A	4 D	5 B
6 B	7 D	8 D	9 A	10 C
11 B	12 D	13 A	14 C	15 D
16 A	17 A	18 B	19 D	20 A
21 C	22 B	23 B	24 C	25 B
26 A	27 C	28 B	29 C	30 D

Detailed Explanations

Question 1 (CISM8-028)

Correct answer: C - A potential cause of an unwanted event that may exploit a vulnerability

A threat is a potential cause of an unwanted event that may exploit a vulnerability. A weakness is a vulnerability, a consequence is an impact, and exposure remaining after controls is residual risk.

Question 2 (CISM8-029)

Correct answer: A - To show exposure before controls and what remains with current controls

The comparison shows uncontrolled exposure and the remaining exposure after current controls, supporting treatment decisions. It does not prove elimination, replace judgment, or guarantee financial return.

Question 3 (CISM8-030)

Correct answer: A - Establish the new context before assessing scenarios

The new market changes obligations, dependencies, and threats, so context must be established before applying risk criteria. Reusing or inflating ratings lacks evidence, and waiting would leave decisions unsupported.

Question 4 (CISM8-031)

Correct answer: D - Reassess availability and integrity impact across the medication-ordering process

The broker is a critical process dependency whose outage or corruption can affect patient care. Temporary storage does not remove availability or integrity impact, and a vendor classification cannot capture the clinic's workflow.

Question 5 (CISM8-032)

Correct answer: B - A shared last-mile failure could disable both providers simultaneously

The common carrier creates concentration risk that the two contracts may conceal. Billing is not the central security exposure, compromise is not guaranteed, and outsourcing alone does not determine risk level.

Question 6 (CISM8-033)

Correct answer: B - Data lifetime, future decryption exposure, crypto-agility, and migration dependencies were omitted

Long-lived data requires scenarios for future decryption and the ability to migrate cryptography. Storage cost is secondary, current controls do not guarantee decades of protection, and immediate universal replacement is not supported without analysis.

Question 7 (CISM8-034)

Correct answer: D - When defined expert judgment must support prioritization despite limited numerical data

Defined qualitative criteria can support consistent prioritization when numerical evidence is limited. They do not create exact forecasts, convert technical severity directly to money, or eliminate business-impact analysis.

Question 8 (CISM8-035)**Correct answer: D - \$180,000**

Single loss expectancy equals asset value multiplied by exposure factor: \$1,500,000 multiplied by 12% equals \$180,000. Event frequency is used only when calculating annualized loss expectancy.

Question 9 (CISM8-036)**Correct answer: A - An incomplete review design**

The documented control omits a relevant account population, so it is deficient by design even when performed correctly. The omission is not itself an impact, operating failure, or proof of misuse.

Question 10 (CISM8-037)**Correct answer: C - Reassess using current controls and document sources, dates, assumptions, owner, and target state**

Current residual risk must use operating controls and traceable evidence, while a planned state is recorded separately. Unsupported assumptions cannot justify the rating, and removing the scenario would hide exposure.

Question 11 (CISM8-038)**Correct answer: B - Unassigned customer responsibilities may leave access and logging controls ineffective**

The mistaken responsibility assumption can leave required customer-side controls unowned. Provider assurance does not cover the institute's configuration, accountability remains, and cloud use alone does not determine inherent risk.

Question 12 (CISM8-039)**Correct answer: D - The migration risk because its transaction impact is imminent**

The closing dependency and near-term timing make migration more urgent despite equal ratings. Data labels and vulnerability counts do not replace business context, and matching scores do not require equal priority.

Question 13 (CISM8-040)**Correct answer: A - A range with assumptions, confidence, and sensitivity**

A range with assumptions and sensitivity transparently represents the evidence and model limitations. A maximum is not an expected value, technical severity is not financial loss, and limited data can still inform decisions.

Question 14 (CISM8-041)**Correct answer: C - Report aggregate concentration while retaining local records**

The common service creates correlated enterprise exposure not visible in separate ratings. Averaging and ignoring aggregation understate impact, while local records remain useful for accountability.

Question 15 (CISM8-042)

Correct answer: D - Material scenarios, appetite, assumptions, and treatments

The board needs business consequences, appetite comparison, assumptions, and response choices. Technical volume and effort do not establish materiality, and buying every control ignores proportionality.

Question 16 (CISM8-043)

Correct answer: A - Discontinuing the activity that creates the exposure

Avoidance removes the risk-producing activity. Insurance shares specified financial loss, controls mitigate risk, and retaining exposure is acceptance.

Question 17 (CISM8-044)

Correct answer: A - The authorized business risk owner

Acceptance is a business decision for the authorized risk owner. Assessors, operators, and auditors provide analysis, execution, or assurance but do not automatically own the consequence.

Question 18 (CISM8-045)

Correct answer: B - Partial financial transfer with other exposure retained

Insurance shares covered financial consequences but leaves operational, reputational, excluded, and accountability exposure. It does not avoid the activity, eliminate impact, or transfer responsibility.

Question 19 (CISM8-046)

Correct answer: D - The compliant option meeting acceptable residual risk

Treatment must satisfy the binding duty and reduce residual exposure appropriately. Cost cannot override the obligation, an administrator lacks authority, and insurance does not replace compliance.

Question 20 (CISM8-047)

Correct answer: A - Choose lower-impact Control Y

Control Y meets risk and obligation criteria with better business value. Higher cost does not prove strength, both are not justified, and acceptable residual risk need not be zero.

Question 21 (CISM8-048)

Correct answer: C - Fund treatment and require acceptable residual-risk evidence at launch

Ownership, funding, and a gate criterion integrate treatment into delivery governance. A later backlog is too late, developers may lack authority, and changing the rating does not reduce exposure.

Question 22 (CISM8-049)

Correct answer: B - Early evidence that exposure is approaching a defined threshold

A KRI signals movement in exposure early enough to support action. Activity counts are often performance metrics, and indicators neither replace assessment nor require realized loss.

Question 23 (CISM8-050)

Correct answer: B - Require risk-tiered data and subcontractor review

Early review preserves leverage to select, negotiate, treat, or seek authorized acceptance. Later review loses leverage, a universal ban may be disproportionate, and procurement does not automatically own all risk.

Question 24 (CISM8-051)

Correct answer: C - Reassess coverage and residual risk before exception approval

The bypass undermines the proposed compensating control, so coverage and residual risk require reassessment. Control presence is insufficient, the path cannot be ignored, and security should not accept for the business.

Question 25 (CISM8-052)

Correct answer: B - Invoke reassessment and a revised owner decision

The approved trigger requires reassessment and a new response decision. Raising it conceals exposure, waiting defeats the indicator, and functioning monitoring does not close the underlying risk.

Question 26 (CISM8-053)

Correct answer: A - Reassess exposure and controls

Repeated renewal, untested compensation, and changed authority require fresh assessment and approval. Automatic renewal, closure, or permanence would lack current evidence and valid authority.

Question 27 (CISM8-054)

Correct answer: C - Reassess because exposure and a key control assumption changed

External access and weaker reconciliation invalidate material assumptions. The same service can have different exposure, and suppliers cannot accept the organization's risk.

Question 28 (CISM8-055)

Correct answer: B - Aggregate concentration, local decisions, trend, and required action

Shared customer and support dependencies create enterprise exposure hidden by local decisions. One asset or severity alone omits business context, and waiting ignores the current appetite breach.

Question 29 (CISM8-056)

Correct answer: C - Use time-bound controls, documented acceptance, monitoring triggers, and a migration deadline

A conditioned and monitored transition supports continuity within approved tolerance. Indefinite acceptance exceeds scope, immediate shutdown ignores the objective, and prior operation is not treatment evidence.

Question 30 (CISM8-057)

Correct answer: D - Material risk, treatment, exceptions, and decisions

Executive reporting should connect exposure to appetite, show treatment results and exceptions, and identify decisions. Raw tasks and spending lack outcome context, while delay prevents timely oversight.